

Informe sobre ISO/IEC 25000, ISO/IEC 25010, IEEE 29119 y OWASP

Introducción

Al desarrollar un sistema web o una aplicación no alcanza con que las funciones básicas respondan. Para entregar un producto estable y profesional hay que controlar la calidad del código, organizarse bien para probarlo antes de que pase a producción y protegerlo contra ataques externos. Para esto existen cuatro herramientas clave en la industria: ISO/IEC 25000, ISO/IEC 25010, IEEE 29119 y OWASP.

Definición de cada concepto

ISO/IEC 25000

Es una serie de normas internacionales (conocida como SQuaRE) que define cómo medir y evaluar la calidad del software. Organiza el proceso en cinco grandes áreas:

ISO/IEC 2500n (Gestión de la calidad): términos generales y guía de uso.

ISO/IEC 2501n (Modelo de calidad): atributos que debe tener un sistema.

ISO/IEC 2502n (Medición): fórmulas y métricas concretas.

ISO/IEC 2503n (Requisitos): cómo definir lo que se le va a exigir al sistema.

ISO/IEC 2504n (Evaluación): procedimientos para revisar si el software cumple o no.

ISO/IEC 25010

Es la parte de la ISO 25000 que detalla los 8 pilares para calificar si un producto está bien hecho:

Adecuación funcional: que haga lo que el usuario y el negocio necesitan.

Eficiencia de desempeño: que sea rápido y no agote la memoria o la CPU.

Compatibilidad: que funcione bien junto a otros sistemas y entornos.

Usabilidad: que la interfaz sea clara, fácil e intuitiva.

Fiabilidad: que no se caiga a cada rato y se recupere bien si hay un fallo.

Seguridad: que los datos estén protegidos contra acceso no autorizado.

Mantenibilidad: que el código esté limpio para arreglar bugs o sumar features sin romper todo.

Portabilidad: que sea fácil de mover a otro servidor o plataforma.

IEEE 29119

Es el estándar global para estructurar el trabajo de testing (QA). Cubre todo el ciclo:

29119-1: Conceptos y lenguaje técnico de pruebas.

29119-2: Cómo organizar los procesos de pruebas (planificación, gestión y ejecución).

29119-3: Formatos para documentos (planes de test, reportes de errores, casos de prueba).

29119-4: Técnicas para diseñar pruebas (caja negra, caja blanca, etc.).

29119-5: Pruebas automatizadas basadas en modelos.

OWASP

Es una comunidad abierta orientada a evitar brechas de seguridad en la web. Sus aportes principales son:

OWASP Top 10: la lista de los 10 ataques y vulnerabilidades más frecuentes en la web (inyección SQL, fallos de autenticación, mal manejo de datos, etc.).

OWASP ASVS: una guía de controles de seguridad que debe tener una app para ser considerada segura.

- OWASP ZAP: herramienta gratuita para hacer escaneos de seguridad y pentesting.

Cuadro comparativo

Resumen de cómo encaja cada concepto en un proyecto real:

Marco	¿Para qué sirve en la práctica?	¿Cuándo se aplica?
ISO 25000 / 25010	Para saber qué exigirle al sistema a nivel de arquitectura, velocidad, usabilidad y calidad general.	Al definir requerimientos y evaluar el producto final.
IEEE 29119	Para armar el plan de pruebas, escribir los casos de test y reportar bugs de manera ordenada.	Durante todo el proceso de desarrollo y QA.
OWASP	Para evitar huecos de seguridad, ataques comunes y vulnerabilidades en la web.	Al programar, configurar servidores y auditar el sistema.

En resumen

Para llevar un proyecto ordenado:

- Con la ISO 25010 defines qué atributos debe tener el sistema.
- Con IEEE 29119 aseguras un testing metódico sin dejar cosas al azar.
- Con OWASP blindas la aplicación contra las vulnerabilidades más comunes de la web.